

A defence-in-depth approach

Implementing a defence-in-depth approach is crucial to safeguard IIoT environments effectively. This strategy mirrors the layers of defence employed in the US military, where multiple layers of protection deter and thwart adversaries at various levels. In the context of IIoT security, consider these layers:



- **Application and data security:** Prioritise timely system patching and encrypt sensitive data.
- **Host security:** Deploy endpoint security tools, security development lifecycle (SDL), and application development security response (ADSR) mechanisms.
- **Network security:** Utilise traditional security measures such as sandboxing, VPNs, and firewalls.
- **Physical security:** Implement access controls, ID card systems, and surveillance to protect physical assets.
- **Policies and processes:** Develop and enforce robust security policies, procedures, and incident response plans.
- **Compliance with standards:** Consider adhering to the IEC 62443 standard, a gold standard for OT security, covering terminologies, concepts, glossaries, policies, procedures, system protection, and security risk assessment.

By integrating these layers of security, IIoT environments can effectively minimise risks, protect critical infrastructure, and ensure the resilience of industrial operations. It is imperative for organisations to recognise the urgency of adopting such a holistic security strategy in safeguarding the future of IIoT.

Security information and event management (SIEM): SIEM tools like QRadar and Splunk can help collect and analyse logs from various IIoT devices, authentication systems, and network components. They provide real-time insights into potential security incidents.

Security orchestration, automation, and response (SOAR): SOAR platforms use predefined playbooks to automate incident response. For example, in the case of a phishing attack, a SOAR platform can take immediate action to remediate the threat without manual intervention.

Security incident and event management (SIEM): SIEM tools are essential for monitoring and managing security events. They provide a centralised platform for collecting, analysing, and responding to security incidents.

Endpoint detection and response (EDR) and extended detection and response (XDR): EDR and XDR solutions use advanced analytics to detect and respond to threats at the endpoint level, providing an additional layer of protection.

A five-step journey to zero trust

A zero trust security model (ZTNA) is gaining prominence in the IIoT security landscape. To implement a zero trust strategy effectively, a systematic approach is essential. To implement it effectively, consider these three core principles:

Least privileged access: Limit access rights to the bare minimum required for an individual's role. Regularly review and adjust permissions to reduce the risk of unauthorised access.

Continuous trust verification: Implement two-factor authentication and regularly re-authenticate users to prevent unauthorised access. Compartmentalise access to different systems to prevent lateral movement by attackers.

Strict network segmentation: Isolate different IIoT components to limit the potential impact of a

compromise. Each component should have its access controls.

Define production services by recognising various environments and compartmentalising assets. Delve into transaction flows within your IIoT ecosystem, for a comprehensive understanding and protection of communication layers. Conduct a thorough analysis of data flows and interdependencies, carefully evaluating the connections between IIoT applications to pinpoint potential vulnerabilities. In the quest for robust security, it is imperative to build the zero trust network, establishing zones and assessing the potential impact of security breaches, and subsequently designing appropriate security measures. Finally, as a critical layer of defence, define zero trust policies that answer the fundamental questions of who can access what, when, where, why, and how, ensuring that your policies align seamlessly with these considerations to fortify security.

IIoT security is an ongoing journey, not a destination. Threats evolve, and vulnerabilities emerge. Regularly monitor and update your security measures to adapt to changing circumstances. By implementing a zero trust security model, leveraging automation, and conducting continuous security inspection, organisations can significantly enhance their IIoT security posture. Additionally, partnering with managed security services providers (MSSPs) can provide valuable expertise and support in safeguarding IIoT environments. Remember, in the world of IIoT, security is a collective responsibility, and vigilance is the key to success. **END**

This article is from a tech talk session at EFY Expo 2023, Pune. It has been transcribed and curated by Akanksha Sondhi Gaur, research analyst and journalist at EFY.

By: Prashasth Bantwal Baliga

The author is principal security consultant (customer success) Palo Alto Networks.

The article was originally published in the March 2024 issue of Electronics For You.